QUY TRÌNH KIỂM SOÁT TRUY CẬP HỆ THỐNG (ACCESS CONTROL SOP)
Source: it/access-control-sop.md
Department: IT Security
Effective Date: 2026-01-01
Access: internal

Ghi chú: Tài liệu này trước đây có tên "Approval Matrix for System Access".

=== Section 1: Phạm vi và mục đích ===
Tài liệu này quy định quy trình cấp phép truy cập vào các hệ thống nội bộ của công ty.
Áp dụng cho tất cả nhân viên, contractor, và third-party vendor.

=== Section 2: Phân cấp quyền truy cập ===

Level 1 — Read Only:
Áp dụng cho: Tất cả nhân viên mới trong 30 ngày đầu.
Phê duyệt: Line Manager.
Thời gian xử lý: 1 ngày làm việc.

Level 2 — Standard Access:
Áp dụng cho: Nhân viên chính thức đã qua thử việc.
Phê duyệt: Line Manager + IT Admin.
Thời gian xử lý: 2 ngày làm việc.

Level 3 — Elevated Access:
Áp dụng cho: Team Lead, Senior Engineer, Manager.
Phê duyệt: Line Manager + IT Admin + IT Security.
Thời gian xử lý: 3 ngày làm việc.

Level 4 — Admin Access:
Áp dụng cho: DevOps, SRE, IT Admin.
Phê duyệt: IT Manager + CISO.
Thời gian xử lý: 5 ngày làm việc.
Yêu cầu thêm: Training bắt buộc về security policy.

=== Section 3: Quy trình yêu cầu cấp quyền ===

Bước 1: Nhân viên tạo Access Request ticket trên Jira (project IT-ACCESS).
Bước 2: Line Manager phê duyệt yêu cầu trong 1 ngày làm việc.
Bước 3: IT Admin kiểm tra compliance và cấp quyền.
Bước 4: IT Security review với Level 3 và Level 4.
Bước 5: Nhân viên nhận thông báo qua email khi quyền được cấp.

=== Section 4: Escalation khi cần thay đổi quyền hệ thống ===
Escalation chỉ áp dụng khi cần thay đổi quyền hệ thống ngoài quy trình thông thường.
Ví dụ: Khẩn cấp trong sự cố P1, cần cấp quyền tạm thời để fix incident.

Quy trình escalation khẩn cấp:
1. On-call IT Admin có thể cấp quyền tạm thời (max 24 giờ) sau khi được Tech Lead phê duyệt bằng lời.
2. Sau 24 giờ, phải có ticket chính thức hoặc quyền bị thu hồi tự động.
3. Mọi quyền tạm thời phải được ghi log vào hệ thống Security Audit.

=== Section 5: Thu hồi quyền truy cập ===
Quyền phải được thu hồi trong các trường hợp:
- Nhân viên nghỉ việc: Thu hồi ngay trong ngày cuối.
- Hết hạn contract: Thu hồi đúng ngày hết hạn.
- Chuyển bộ phận: Điều chỉnh trong 3 ngày làm việc.

=== Section 6: Audit và review định kỳ ===
IT Security thực hiện access review mỗi 6 tháng.
Mọi bất thường phải được báo cáo lên CISO trong vòng 24 giờ.

=== Section 7: Công cụ liên quan ===
Ticket system: Jira (project IT-ACCESS)
IAM system: Okta
Audit log: Splunk
Email: it-access@company.internal